

原创张东南于 2020-11-25 17:20:46 发布3339收藏3

文章标签：安全其他zip

版权

使用场景

一般破解 加密 压缩包文件常规的方式主要有穷举、字典破解等方法。穷举破解的方式效率太低，字典破解需要碰运气。但是如果手上刚好有加密zip中的某个文件时，可以使用明文破解。这种方式利用了加密算法的BUG，相比穷举，能提高破解效率。但是有一个限制：我们把所持有的文件暂且成为明文文件(plaintext)，该文件的大小必须大于12Byte

环境&准备

Ubuntu 20.04LTS

字符集

字符集需要注意的有3点：

- 系统使用的字符集
- 压缩文件使用的字符集
- 终端(Terminal)使用的字符集

一般windows下zip压缩包使用GBK编码(又称CP936编码)，Ubuntu系统使用的是UTF-8编码。当使用unzip命令时，默认采用UTF-8编码读取文件名，此时输出到终端为乱码，解决方案有两种：

- 改变系统的编码

```
1 # 改变编码
2 export LANG=zh_CN.GBK
3 # 查看结果
4 locale
```

系统编码改完后，unzip就会使用GBK编码读取文件名。但还要注意一点，如果程序输出的是GBK编码，而终端以UTF-8编码展示，会出现一堆的问号，此时需要修改终端，比如xshell、x-terminal-emulator的字符集为GBK编码

```
1 # 打印压缩包信息
2 unzip -v xxx.zip
```

- 直接使用unzip命令提供的-O参数

```
1 # 打印压缩包信息，以下命令指明压缩包的字符集为GBK，所以unzip会把压缩包中的GBK格式转为UTF-8格式输出到终端
2 unzip -O CP936 -v xxx.zip
```

压缩文件

使用pkcrack进行明文破解需要注意一点：压缩包中可能包含多个加密文件，但我们只要持有其中一个文件即可，该文件必须和压缩包中的某个文件一模一样。在破解前，需要先把明文文件进行压缩。如果使用zip命令直接压缩可能会出现压缩率的问题。windows下可以使用7-zip一类的桌面应用进行压缩。使用7-zip进行压缩时，会有一个压缩率的选项，可以调整 word size 的大小，如果这个压缩率和加密文件的压缩率不匹配，破解时可能会出现文件长度不匹配问题

```
1 #查看加密压缩包的压缩率，windows下可以借助winrar、360压缩、7zip等查看
2 zipdetails -v xxx.zip
```

```
1 0664 0004 50 4B 01 02 CENTRAL HEADER #1 02014B50
2 0668 0001 1E          Created Zip Spec 1E '3.0'
3 0669 0001 03          Created OS      03 'Unix'
4 066A 0001 14          Extract Zip Spec 14 '2.0'
5 066B 0001 00          Extract OS      00 'MS-DOS'
6 066C 0002 00 00      General Purpose Flag 0000
7                               [Bits 1-2] 0 'Normal Compression'
8 066E 0002 08 00      Compression Method 0008 'Deflated'
9 0670 0004 E9 AE 78 51 Last Mod Time 5178AEE9 'Tue Nov 24 21:55:18 2020'
10 0674 0004 B2 EF 76 9E CRC 9E76EFB2
11 0678 0004 FE 05 00 00 Compressed Length 000005FE
12 067C 0004 F0 0B 00 00 Uncompressed Length 00000BF0
13 0680 0002 2C 00      Filename Length 002C
14 0682 0002 18 00      Extra Length 0018
15 0684 0002 00 00      Comment Length 0000
16 0686 0002 00 00      Disk Start 0000
17 0688 0002 00 00      Int File Attributes 0000
18                               [Bit 0] 0 'Binary Data'
19 068A 0004 00 00 B4 81 Ext File Attributes 81B40000
20 068E 0004 00 00 00 00 Local Header Offset 00000000
21 0692 002C 63 6C 69 63 Filename 'clickhouse-client-1.1.54236-
22                               6B 68 6F 75 4.e16.x86_64.rpm'
23                               73 65 2D 63
24                               6C 69 65 6E
25                               74 2D 31 2E
26                               31 2E 35 34
27                               32 33 36 2D
28                               34 2E 65 6C
29                               36 2E 78 38
30                               36 5F 36 34
31                               2E 72 70 6D
32
```

安装pkcrack

```
1 cd /root/pkcrack
2 vim install.sh
```

```
3 wget https://www.unix-ag.uni-kl.de/~conrad/krypto/pkcrack/pkcrack-1.2.2.tar.gz
4 tar xzf pkcrack-1.2.2.tar.gz
5 cd pkcrack-1.2.2/src
6 make
7
8 mkdir -p ../../bin
9 cp extract findkey makekey pkcrack zipdecrypt ../../bin
10 cd ../../
```

```
1 chmod +x install.sh
2 ./install.sh
```

执行破解

```
1 #设置字符集
2 export LANG=zh_CN.GBK
3 #如果明文文件在压缩包中的文件名刚好是中文，可以使用以下的子shell形式获取文件名，就不会出现编码问题
4 bin/pkcrack -C /root/pkcrack/crypt.zip -c $(unzip -v crypt.zip | grep 'info' | cut -d ' ' -f 19) -P /root/pkcrack/plaintext.zip -p '明文文件.info' -d
```

参数解读

- C:要破解的目标文件(含路径)
- -c:破解文件中的明文文件的名字(其路径不包括系统路径,从zip文件一层开始)
- -P:压缩后的明文文件
- -p:压缩的明文文件中明文文件的名字(也就是 明文文件.info 在 plaintext.zip 中的位置) -
- d:指定文件名及所在的绝对路径，将解密后的zip文件输出

补充说明

- pkcrack的破解分为对压缩文档的破解和对压缩文档密码的破解，直接破解压缩文档只需要计算出3个关键的key，计算这3个key的效率非常高。而计算压缩文档密码则需要在算出来3个key的基础上再进行穷举，虽然比一般的非明文破解的穷举效率要高，但是根据密码的长度，计算难度呈指数级增长。所以当密码非常长的情况下，破解难度相当大。其实无论什么情况下，直接破解文档都比破解密码更划算，因为破解密码最终也还是为了拿到文件。。。
- 当命令带-d参数时，pkcrack会直接对 通常情况下，pkcrack程序执行后，会先计算出3个key，再根据这3个key直接生成未加密的压缩文档。如下，是stdin打印出来的三个key。如果没有加-d参数，则会计算压缩文档的密码

```
1 Ta-daaaaa! key0=a6f3eaa9, key1=798254cd, key2=1f5aeeee1
2 Probabilistic test succeeded for 1510 bytes.
3 Ta-daaaaa! key0=a6f3eaa9, key1=798254cd, key2=1f5aeeee1
4 Probabilistic test succeeded for 1510 bytes.
5 Ta-daaaaa! key0=a6f3eaa9, key1=798254cd, key2=1f5aeeee1
6 Probabilistic test succeeded for 1510 bytes.
7 Ta-daaaaa! key0=a6f3eaa9, key1=798254cd, key2=1f5aeeee1
8 Probabilistic test succeeded for 1510 bytes.
```

- 如果一开始没加-d参数，而程序也一直没有得到密码，当程序打印出3个key后，就可以使用bin下的zipdecrypt命令破解该压缩文档，得到未加密的压缩文档，使用方法如下：

```
1 zipdecrypt key0 key1 key2 encrypted_archive decrypted_archive
```

```
1 #最后使用unzip命令解压,加-O防止乱码
2 unzip -O CP936 decrypted_archive.zip
```

- 明文文件必须大于12Byte是由pkzip的规范决定的，pkzip会在加密前，在压缩文件的文件前加12Byte的随机数/CRC校验值。所以pkcrack程序内部会判断，如果明文文件和加密文件的文件大小有差异，差异大于或小于12Byte都会报错。
- 超大的压缩文件使用pkcrack生成压缩包时可能出现签名错误的问题，使用unzip和winrar解压被解密过的压缩包可能会出现压缩包损坏的情况，经测试使用7zip解压不会报错

```
1 sudo apt-get install p7zip convmv
2 #LANG=C 表示以US-ASCII 这样的编码输出文件名
3 LANG=C 7za x your-zip-file.zip
4 #上条命令解压的文件可能出现乱码，使用convmv命令，它会通过mv命令将文件逐条从GBK编码的文件名转化为UTF8编码，-r表示递归访问目录
5 convmv -f GBK -t utf8 --notest -r .
```

参考资料

记一道明文破解的漫长斗争史

☐

显示推荐内容

张东南

关注

 0



 3



 0

